

ECDAT

ENTERPRISE CRYPTOGRAPHIC DISCOVERY & ANALYSIS TOOL

Automated Post-Quantum Readiness, Temporal Risk Modeling & Tamper-Evident CBOM

Problem Statement ID : SIH26164

Problem Statement Title : Enterprise Cryptographic Discovery & Analysis Tool

Theme : Blockchain & Cybersecurity

PS Category : Software

Team ID : [Your Team ID]

Team Name : [Your Team Name]

IDEA TITLE: ECDAT

SIH26164 — Proposed Solution, Problem Analysis, and Core Innovations

50.7%

Internet Domains Classically
Vulnerable
2026 Measurement Study

2030 / 2035

NIST IR 8547 & OMB M-26-15
Deprecation & Disallowance Dates

4-Tier

Automated X-Inference Classification
EPHEMERAL · OPERATIONAL · ARCHIVAL · REVIEW

32 Bytes

Merkle Commitment Root
Privacy-Preserving Audit Verification

PROBLEM STATEMENT

- ▶ NIST IR 8547 mandate: RSA, ECDSA, ECDH deprecated by 2030, disallowed by 2035; OMB M-26-15 mandates automated PQC discovery plans by Oct 2026
- ▶ Enterprises possess thousands of uncataloged crypto assets across source code, legacy certs, microservices, and containers with zero visibility
- ▶ Harvest-Now-Decrypt-Later (HNDL) threat: adversaries archive today's encrypted data to crack with future Cryptanalytically Relevant Quantum Computers (CRQC)
- ▶ Conventional discovery tools export complete plaintext inventories, inadvertently exposing sensitive internal architecture and cryptographic call sites in audit reports

HOW IT ADDRESSES THE PROBLEM

- ▶ Eliminates manual tagging: automated taint & dataflow analysis classifies each crypto asset's data lifespan X into four tiers — EPHEMERAL, OPERATIONAL, ARCHIVAL, or HUMAN_REVIEW — based on persistence sink analysis
- ▶ Anchors risk to regulatory truth: maps directly to OMB M-26-15 5-phase timeline and Global Risk Institute quantum arrival distributions
- ▶ Secures the inventory itself: Merkle tree commitment scheme publishes only a 32-byte root; auditors verify compliance via selective proofs without accessing internal code paths
- ▶ Crypto-shredding guidance: flags cases where destroying the encryption key reduces X classification from ARCHIVAL to effectively EPHEMERAL, dramatically improving migration priority

PROPOSED SOLUTION (ECDAT)

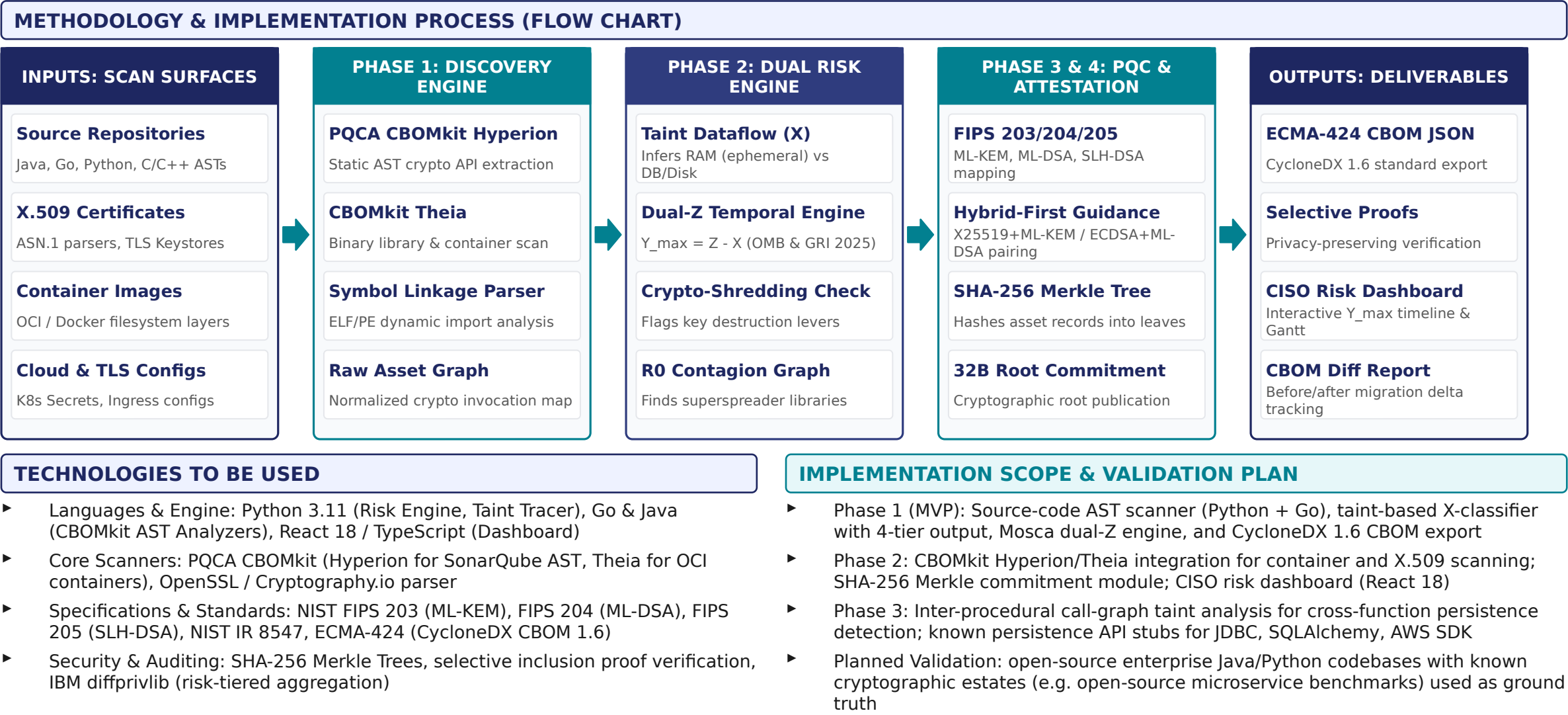
- ▶ End-to-end 5-Layer Cryptographic Discovery, Temporal Risk Scoring, and PQC Migration Platform
- ▶ Multi-surface discovery: parses source code ASTs, X.509 keystores, container images, and cloud TLS configurations
- ▶ Planning-centric Mosca Engine: computes $Y_{\max} = Z - X$ (available migration window) instead of a naive binary compliance flag
- ▶ Standards-compliant CBOM generation (CycloneDX 1.6 / ECMA-424) with hybrid-first FIPS 203/204/205 recommendations
- ▶ Interactive CISO risk dashboard with dependency contagion modeling and drill-down to exact code sites

INNOVATION & UNIQUENESS

- ▶ Privacy-Preserving CBOM via Merkle Commitments: enables external compliance auditing via selective inclusion proofs without exposing internal code paths
- ▶ Actionable Mosca Metric ($Y_{\max} = Z - X$): treats migration time as an engineering budget per asset; identifies crypto-shredding levers to shrink X
- ▶ Multi-tier X-inference: four data-lifespan tiers (EPHEMERAL / OPERATIONAL / ARCHIVAL / HUMAN_REVIEW) with call-graph-aware taint tracing across module boundaries
- ▶ Regulatory-physical dual-Z model: evaluates both the OMB M-26-15 compliance deadline and the GRI 2025 probabilistic CRQC arrival distribution separately

TECHNICAL APPROACH

SIH26164 — Methodology & Implementation Process (Flow Chart), Tech Stack & Working Prototype



FEASIBILITY AND VIABILITY

SIH26164 — Operational Feasibility, Risk Analysis, and Mitigation Strategies

FEASIBILITY ANALYSIS

- ▶ **Technical Feasibility:** Built on Linux Foundation's PQCA CBOMkit — builds upon industry-standard AST engines rather than reinventing crypto scanning from zero
- ▶ **Operational Feasibility:** Generates CycloneDX 1.6 / ECMA-424 JSON — natively interoperable with existing enterprise SBOM and CI/CD pipelines (e.g. SonarQube, GitHub Actions)
- ▶ **Security & Privacy Feasibility:** Completely local execution (zero cloud leakage of CBOM data); Merkle root proofs satisfy external audits without exposing codebase paths
- ▶ **Economic Feasibility:** Portfolio optimization (Markowitz efficient frontier) enables CISOs to allocate migration budget for maximum risk reduction per dollar

POTENTIAL CHALLENGES & MITIGATION STRATEGIES

Identified Challenge & Risk	Engineered Strategy & Mitigation
Detailed Inventory Exposure: Standard plaintext CBOM reports expose sensitive internal file paths, module names, and key configurations during external audits.	Cryptographic Merkle Commitment: Publishes a 32-byte root. Auditors verify specific compliance claims via selective inclusion proofs without accessing full internal inventories.
Ambiguous Data Lifespan (X): Static code analysis cannot inherently determine how long encrypted records will be retained.	Taint & Dataflow Persistence Tracing: Automatically checks whether ciphertexts reach persistent storage (DB/Disk/S3) vs ephemeral memory; flags low confidence for human review.
Inter-procedural Persistence Detection: When a ciphertext is passed into a third-party function or external library call, static taint analysis cannot determine whether that function writes to persistent storage.	Call-Graph API Stubs + HUMAN_REVIEW Tier: ECDAT ships pre-annotated stubs for common persistence APIs (JDBC, SQLAlchemy, S3 SDK). For unresolved external sinks, assets are automatically escalated to the HUMAN_REVIEW X-tier with a confidence score.
Binary Stripped Cryptography: Compiled binaries without symbols or source code are computationally expensive to decompile.	Tiered Ingestion Triage: Fast symbol/import table scanning for MVP; automated Ghidra headless decompilation scheduled as an explicit enterprise roadmap tier.

IMPACT AND BENEFITS

SIH26164 — Multi-Stakeholder Value Proposition & Strategic National Impact

TARGET AUDIENCE IMPACT (WHO BENEFITS & HOW)

- ▶ Chief Information Security Officers (CISOs): Replaces subjective audit checklists with a quantifiable, ranked migration backlog; portfolio optimization maximizes risk reduction per budget dollar
- ▶ Compliance & Internal Audit Teams: Automated CBOM generation natively satisfies NIST IR 8547, OMB M-26-15, and CNSA 2.0 requirements without manual questionnaire audits
- ▶ Software Engineering Teams: Taint-based X-inference filters out thousands of ephemeral low-risk keys, pinpointing the critical persistent-data call sites that truly require migration
- ▶ Critical Infrastructure & Regulated Sectors: Banking, healthcare, defense, and government agencies secure long-lived data against HNDL attacks well ahead of the 2030/2035 mandates
- ▶ DevSecOps & Open-Source Communities: CBOM export pipeline integrates natively with CI/CD workflows (GitHub Actions, SonarQube), automating PQC compliance checks on every code merge

BROADER BENEFITS (SECURITY, ECONOMIC & NATIONAL IMPACT)

- ▶ Strategic National Cybersecurity: Directly neutralizes 'Harvest Now, Decrypt Later' (HNDL) intelligence gathering against national sensitive data and citizen registries
- ▶ Economic Efficiency: Avoids costly, reactive blanket replacements; targeted Mosca planning ($Y_{max} = Z - X$) prioritizes high-yield remediation and crypto-shredding levers first
- ▶ Tamper-Evident Accountability: Merkle commitment history provides an immutable audit trail, preventing retroactive compliance claims in post-incident forensic investigations
- ▶ Open Ecosystem Interoperability: Adopting ECMA-424 / CycloneDX CBOM standards prevents vendor lock-in and enables seamless integration with existing SIEM/SOAR infrastructure
- ▶ National Infrastructure Resilience: Establishes a verifiable, proactive post-quantum migration framework across critical enterprise systems

RESEARCH AND REFERENCES

SIH26164 — Standards Grounding, Peer-Reviewed Prior Art & Experimental Validation

PRIMARY STANDARDS & REGULATORY MANDATES

- ▶ NIST IR 8547 (Nov 2024): 'Transition to Post-Quantum Cryptography Standards' — Sets official deprecation (2030) and disallowance (2035) dates for classical public-key cryptography
- ▶ NIST FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA) (Aug 2024): Official post-quantum standards defining lattice-based and hash-based cryptographic primitives
- ▶ Executive Order 14412 & OMB M-26-15 (June 24, 2026): Mandates 5-phase federal PQC migration; requires automated discovery tooling inventory plans by October 2026
- ▶ OWASP CycloneDX / ECMA-424 v1.6: International Cryptography Bill of Materials (CBOM) specification; establishes standard schema for cryptographic asset reporting

PEER-REVIEWED LITERATURE & COMPETITIVE BENCHMARKS

- ▶ IBM Research, 'Cryptoscope: Analyzing Cryptographic Usages in Modern Software' (arXiv:2503.19531, March 2025): CamBench benchmark (92% recall, 97% precision) for static crypto AST analysis
- ▶ Blanco-Romero et al., 'On the Practical Feasibility of Harvest-Now, Decrypt-Later Attacks' (arXiv:2603.01091, March 2026): Empirical HNDL economics & TLS 1.3 KeyUpdate cascade analysis
- ▶ Global Risk Institute, 'Quantum Threat Timeline Report 2025': Annual survey tracking quantum computing hardware milestones; empirical source for physical-Z distribution (28-49% 10-year CRQC probability)
- ▶ Linux Foundation Post-Quantum Cryptography Alliance (PQCA): Open-source CBOMkit project (github.com/PQCA/cbomkit) providing community AST extraction modules
- ▶ IETF RFC 9180 / draft-ietf-tls-ecdhe-mlkem: Standards track for hybrid post-quantum key exchange (X25519MLKEM768) in TLS 1.3

VALIDATION APPROACH

Planned validation uses open-source enterprise codebases with known cryptographic profiles as ground truth (e.g., open-source Java microservice frameworks and Python web services). ECDAT's risk classifications and X-tier assignments will be compared against manually audited inventories to measure recall, precision, and HUMAN_REVIEW escalation rates for the inter-procedural taint analysis module.